CLOUDHELDEN.ORG

IHK AP-2 FISI - TEIL 2

Prüfungsvorbereitung

Analyse und Entwicklung von Netzwerken

CLOUDHELDEN.ORG

CLOUDHELDEN.ORG

Einführung

Ausgangssituation vorstellen

Jede Probeklausur enthält eine Ausgangssituation, die einen fiktiven Kontext darstellt.

Aufgaben durcharbeiten

Aufgabenteile 1 bis 4 werden nacheinander vorgestellt. Dabei wird zunächst die Frage vorgestellt, Hinweise gegeben und anschließend die Lösung erklärt.

Kahoot

Zur Festigung der besprochenen Inhalte wird ein Kahoot Quiz durchgespielt.

CLOUDHELDEN.ORG

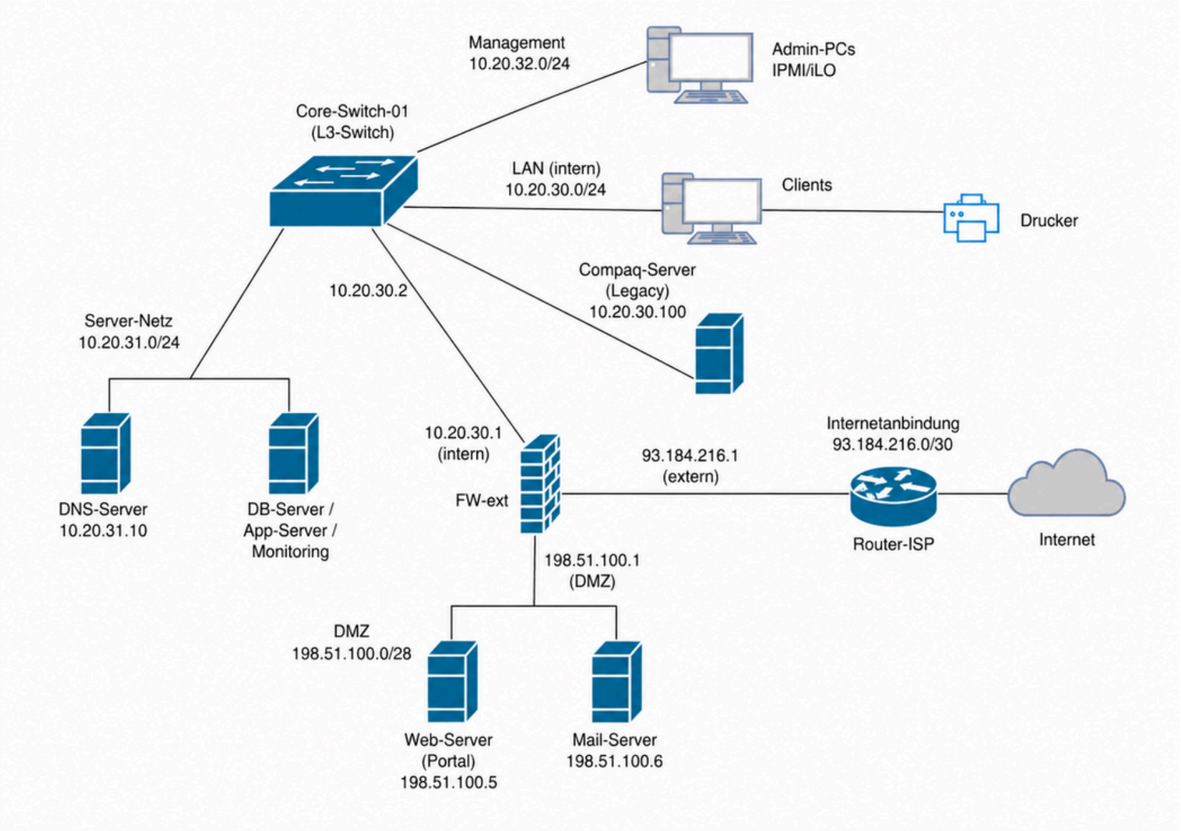
Ausgangssituation

Sie arbeiten als Fachinformatiker bei der NetSecure Solutions GmbH, einem IT-Dienstleister, der sich auf Netzwerkinfrastruktur und IT-Sicherheit spezialisiert hat. Ein Kunde, der Energieversorger Green Energy AG, beauftragt Sie mit der Weiterentwicklung seiner Netzwerkinfrastruktur. Die Green Energy AG betreibt ein Kundenportal für Energieverbrauchsdaten und möchte dieses hochverfügbar und sicher gestalten. Den Ist-Zustand des Netzwerks finden Sie im nachfolgenden Netzplan.

Neuorganisation des Netzwerks (Layer-2 + Layer-3) → Einführung von Load Balancing für das Kundenportal → Einführung von IPv6 → Konzeptionierung einer VPN-Lösung

CLOUDHELDEN.ORG

Netzplan



CLOUDHELDEN.ORG

Aufgabe 1: Neuorganisation des Netzwerks

Das Netzwerk der Green Energy AG besteht aus folgenden Segmenten:

Segment	Netz	Geräte
LAN (intern)	10.20.30.0/24	Core-Switch-01, Clients, Drucker
DMZ	198.51.100.0/28	Web-Server (Portal), Mail-Server, FW-ext
Server-Netz	10.20.31.0/24	DB-Server, App-Server, Monitoring
Management	10.20.32.0/24	Admin-PCs, IPMI/iLO
Internetanbindung	93.184.216.0/30	FW-ext, Router-ISP

Weitere Informationen:

- Firewall extern (FW-ext): IP intern 10.20.30.1, IP DMZ 198.51.100.1, IP extern 93.184.216.1
- Core-Switch-01: L3-Switch, IP 10.20.30.2/24
- DNS-Server: 10.20.31.10
- Web-Server (Portal): 198.51.100.5
- Compaq-Server (Legacy): 10.20.30.100

CLOUDHELDEN.ORG

1.1 Netzgröße

Für die **demilitarisierte Zone (DMZ)** und für das **Server-Netz** sollen die IP-Adressierung Informationen vervollständigt werden.

Ermitteln Sie rechnerisch den **Gesamtbereich des Netzes** der DMZ sowie die **maximale Anzahl** an weiteren adressierbaren Geräten.

CLOUDHELDEN.ORG

Lösung

Netzgröße DMZ:

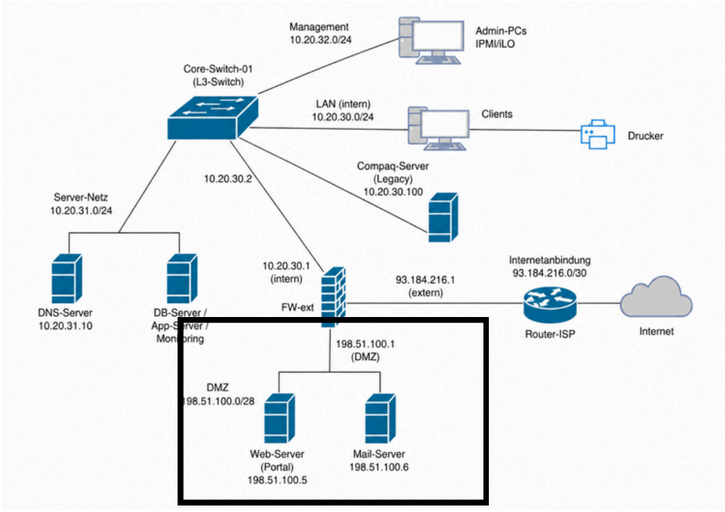
Ausgangsinformation: Subnetz war 198.51.100.0/28

Anforderung: Ermitteln die Gesamtgröße des Netzes und die maximale Anzahl weiterer Geräte.

1. Anlegen der Subnetzmaske in Binär:
/28 = 255.255.255.240 = 11111111.11111111.11111111.11110000
→ 4 Bits für Host Adressierung verfügbar

2. Ermitteln der maximalen Anzahl an möglichen Hosts:
2^4 - 2 (Netz-ID + Broadcast) = 14 → 14 verfügbare Adressen
Erste moöliche Adresse: 198.51.100.1
Letzte mögliche Adresse: 198.51.100.14

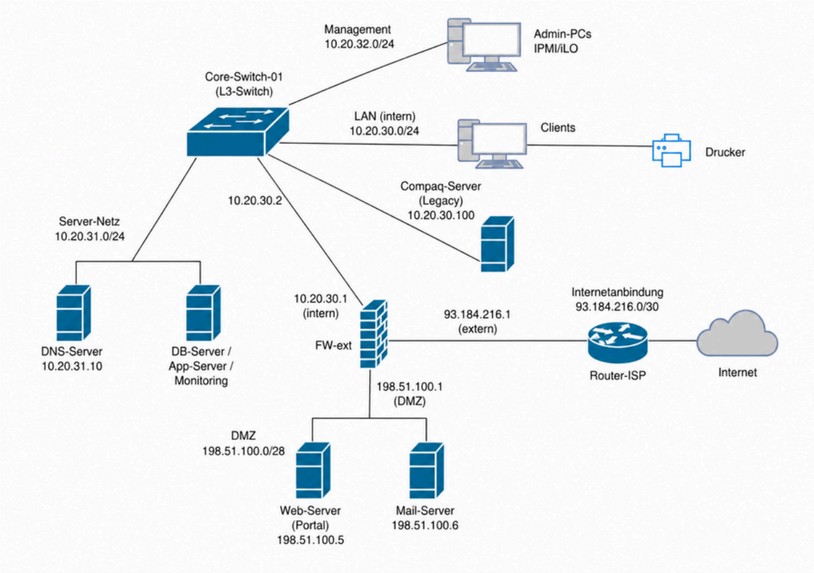
3. Definition des Adressbereichs: 198.51.100.1 - 198.51.100.14
Anzahl der aktuell bereits verwendeten Adressen = 3 (FW-ext, Web-Server, Mail-Server)
→ Maximale Anzahl an weiteren Geräten = 14 - 3 = 11



1.2 IP-Adresse des L3 Core Switches

Für die DMZ sollen die IP-Adressierung Informationen vervollständigt werden.

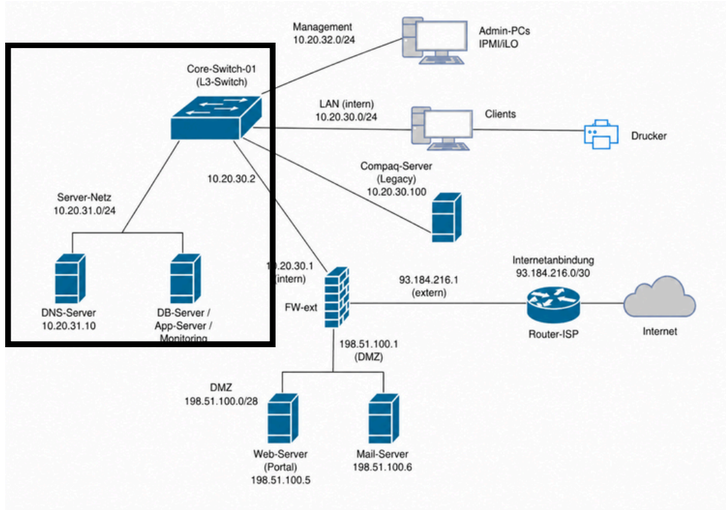
Erläutern Sie die **IP-Adresse** des **L3 Core Switches** im **Server-Netz**. Verwenden Sie hierfür die letzte verwendbare IP-Adresse des Subnetzes. Die Herleitung ist anzugeben.



CLOUDHELDEN.ORG

IP-Adresse für den L3 Core Switch:
Ausgangsinformation: Subnetz (Server-Netz) 10.20.31.0/24

Lösung



1. Anlegen der Subnetzmaske in Binär:
/24 = 255.255.255.0 = 11111111.11111111.11111111.00000000
→ 8 Bit für Host Adressierung verfügbar

2. Ermitteln der Netzgröße:
2^8 = 256 (Netz-ID + Broadcast) = 254 nutzbare Adressen
Erste mögliche Adresse: 10.20.31.1
Letzte mögliche Adresse: 10.20.31.254

3. Definition der IP-Adresse für Core Switch:
→ Laut Angabe: "Letzte verwendbare IP im Subnetz" → 10.20.31.254

CLOUDHELDEN.ORG

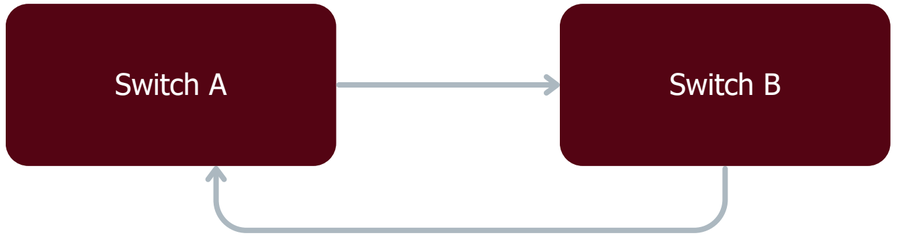
1.3 Fehler im Netzwerk

Nach dem Umbau der Switching-Infrastruktur erhalten Sie von diversen Benutzern Beschwerden, dass keine Netzwerkkommunikation mehr möglich sei. Sie greifen dieses Fehlerbild beispielhaft am Client Marketing-02 auf. Ein PING-Befehl und ein anschließender Trace ergeben das nachfolgende Ergebnis:

Nr.	Time	Source	Protocol	Length	Info
1	0	10.20.30.55	STP	60	Conf. Root=32768/10
2	2.003.177	10.20.30.55	STP	60	Conf. Root=32768/10
3	11.413.297	10.20.30.2	STP	60	RST. Root=4096/10
4	13.407.218	10.20.30.2	STP	60	RST. Root=4096/10
5	21.486.230	10.20.30.55	STP	60	Conf. Root=32768/10
6	24.881.476	10.20.30.2	STP	851	RST. TC Root=4096/10

a) Nennen Sie den Namen und die Funktion des im Trace erfassten Protokolls und leiten Sie die mögliche Fehlerursache ab. (2 Punkte)

CLOUDHELDEN.ORG



Lösung

Zu a)

Spanning Tree Protocol (STP).

- **F**unktion: Netzwerkprotokoll, das in lokalen Netzwerken (LANs) verwendet wird, um Schleifen zu verhindern, die durch redundante Pfade entstehen können.
- Mögliche Fehlerursache: Die generelle Problematik basiert auf einer Netzwerkschleife innerhalb der Switching-Infrastruktur, die im Rahmen des Umbaus in einzelnen Bereichen aufgetreten ist.

- Die **Root Bridge** ist der zentrale Switch im STP-Netzwerk, von dem aus alle Pfade berechnet werden.
- **BPDUs** sind Steuerpakete, die zwischen Switches ausgetauscht werden, um die Netzwerktopologie zu bestimmen.
- Ein **Designated Port** ist der Port eines Segments, der den besten Pfad zur Root Bridge hat und für die Weiterleitung von Daten verantwortlich ist.

STP macht:
- wählt eine Root Bridge
- blockiert überflüssige Verbindungen

Aber hier: Root wechselt ständig und Ports ändern ständig den Zustand, Netzwerk also instabil

FEHLERURSACHE

Netzwerkschleife (Loop)
Sehr wahrscheinlich durch den Umbau:
- Zwei Switches sind mehrfach verbunden
- STP erkennt das und versucht zu reagieren
- Aber:
  - ständig wechselnde Root Bridge
  - Topology Changes (TC im Trace!)

Netz „flappt" → keine stabile Verbindung

Nr.	Time	Source	Protocol	Length	Info
1	0	10.20.30.55	STP	60	Conf. Root=32768/10
2	2.003.177	10.20.30.55	STP	60	Conf. Root=32768/10
3	11.413.297	10.20.30.2	STP	60	RST. Root=4096/10
4	13.407.218	10.20.30.2	STP	60	RST. Root=4096/10
5	21.486.230	10.20.30.55	STP	60	Conf. Root=32768/10
6	24.881.476	10.20.30.2	STP	851	RST. TC Root=4096/10

Das bedeutet:
- Zwei Geräte „streiten" sich darum, wer die Root Bridge ist

Unterschiedliche Prioritäten:
- 32768 (Standard)
- 4096 (niedriger → besser!)

Ergebnis:
- STP wird ständig neu berechnet
- Netzwerk ist instabil
- Kommunikation bricht zusammen

TC = Topology Change
Das Netzwerk ändert sich ständig

CLOUDHELDEN.ORG

1.4 SFTP und FTP

Zur Aktualisierung der Energieverbrauch Berichte werden die Daten aus der Abrechnungsabteilung täglich auf einen SFTP-Server des externen Dienstleisters übertragen.

Erläutern Sie den technischen Unterschied zwischen SFTP und FTP. Gehen Sie dabei auch auf die Aspekte "aktives" und "passives" FTP ein und begründen Sie Ihre Antwort.

CLOUDHELDEN.ORG

Lösung

FTP (File Transfer Protocol)

- Überträgt Dateien unverschlüsselt
- Benutzername, Passwort und Daten sind im Klartext sichtbar
- Läuft typischerweise über:
  - Port 21 (Steuerverbindung)
  - separate Datenverbindung

Problem:

Jeder im Netzwerk kann die Daten mitlesen (z. B. Sniffing)

SFTP (SSH File Transfer Protocol)

- Läuft über SSH (Secure Shell)
- Alles ist verschlüsselt:
  - Login-Daten
  - Dateiübertragung
- Nutzt nur:
  - einen Port (Standard: 22)
- Vorteil:
  - Sicher gegen:
    - Mithören (Sniffing)
    - Man-in-the-Middle-Angriffe

CLOUDHELDEN.ORG

Lösung

Aktives vs. Passives FTP

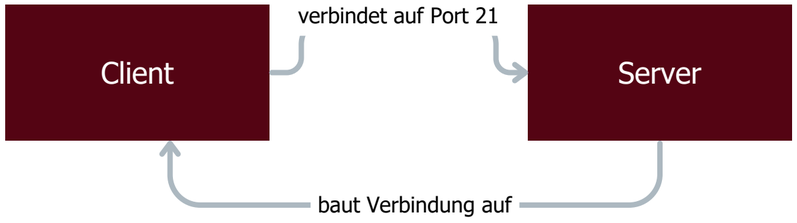
Das betrifft nur FTP, nicht SFTP!

Aktives FTP

1. Client verbindet sich zum Server (Port 21)
2. Client sagt: „Schick mir Daten"
3. Server baut Datenverbindung zum Client auf

Problem:

- Client muss von außen erreichbar sein
- Firewall blockiert oft eingehende Verbindungen

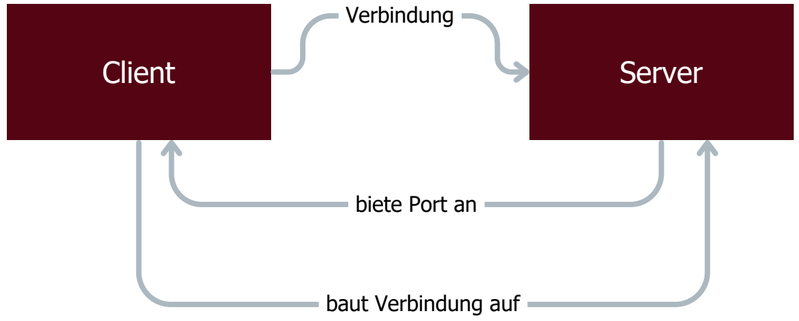


Passives FTP

1. Client verbindet sich zum Server
2. Server sagt: „Nutze diesen Port"
3. Client baut selbst die Datenverbindung auf

Vorteil:

- Funktioniert besser mit Firewalls
- Heute Standard



CLOUDHELDEN.ORG

1.5 Dauer der Datenübertragung berechnen

Die Green Energy AG plant zukünftig die Digitalisierung von historischen Netzplänen. Hierbei müssen analoge Pläne gescannt, digital aufbereitet und dann ebenfalls per SFTP an einen Archiv-Server übertragen werden.

Berechnen Sie die Zeit des Transfers eines Plans unter Verwendung der folgenden Rahmenparameter:

- Upload-Geschwindigkeit: 8 Mbit/s
- Plangrösse: 42 cm (Breite) x 59,4 cm (Hoehe) (DIN A2)
- Scanauflösung: 600 DPI
- Farbtiefe: 24 Bit

Hinweis: 2,54cm = 1 Inch

Runden Sie Ihr Ergebnis auf zwei Nachkommastellen.

CLOUDHELDEN.ORG

GEGEBENE DATEN:

- UPLOAD-GESCHWINDIGKEIT: 8 MBIT/S
- PLANGRÖSSE: 42 CM (BREITE) X 59,4 CM (HÖHE)
- SCANAUFLÖSUNG: 600 DPI
- FARBTIEFE: 24 BIT
- 1 INCH = 2,54 CM

Lösung

1. Umrechnung von cm auf Inch:
42 cm / 2,54 cm = 16,5354331 Inch
59,4 cm / 2,54 cm = 23,3858268 Inch

2. Berechnung der Pixelanzahl:
→ 600 DPI = 600 Dots per Inch
Pixel (Breite) = 16,5354331 Inch x 600 DPI = 9.921,25986 → Pixel = 9.921,25986 Pixel
Pixel (Höhe) = 23,3858268 Inch x 600 DPI = 14.031,4960 → Pixel = 14.031,4960 Pixel
Gesamt Pixel: Pixel Breite x Pixel Höhe = 9.921,25986 Pixel x 14.031,4960 Pixel = 139.210.118,041 Pixel

3. Berechnung der Dateigröße in Bit:
→ Farbtiefe: 24 Bit. Dateigröße = 139.210.118,041 Pixel x 24 Bit = 3.341.042.832,97 Bit

4. Umrechnung der Dateigröße in Megabit (Mbit):
1 Megabit = 1.000.000 Bits
Dateigröße (Mbit) = 3.341.042.832,97 Bit / 1.000.000 = 3.341,04283297 Mbit

5. Berechnung der Transferzeit:
Dateigröße / Übertragungsrate = 3.341,04283297 Mbit / 8 Mbit/s = 417,630354122 s
→ ca. 417,63 Sekunden (ca. 6 Minuten und 58 Sekunden)

CLOUDHELDEN.ORG

Aufgabe 2: Einführung von Load Balancing für das Kundenportal

CLOUDHELDEN.ORG

2.1 Load Balancer

Zur Verbesserung der Leistungsfähigkeit des Kundenportals soll die Einführung eines Load Balancers in der DMZ geplant werden.

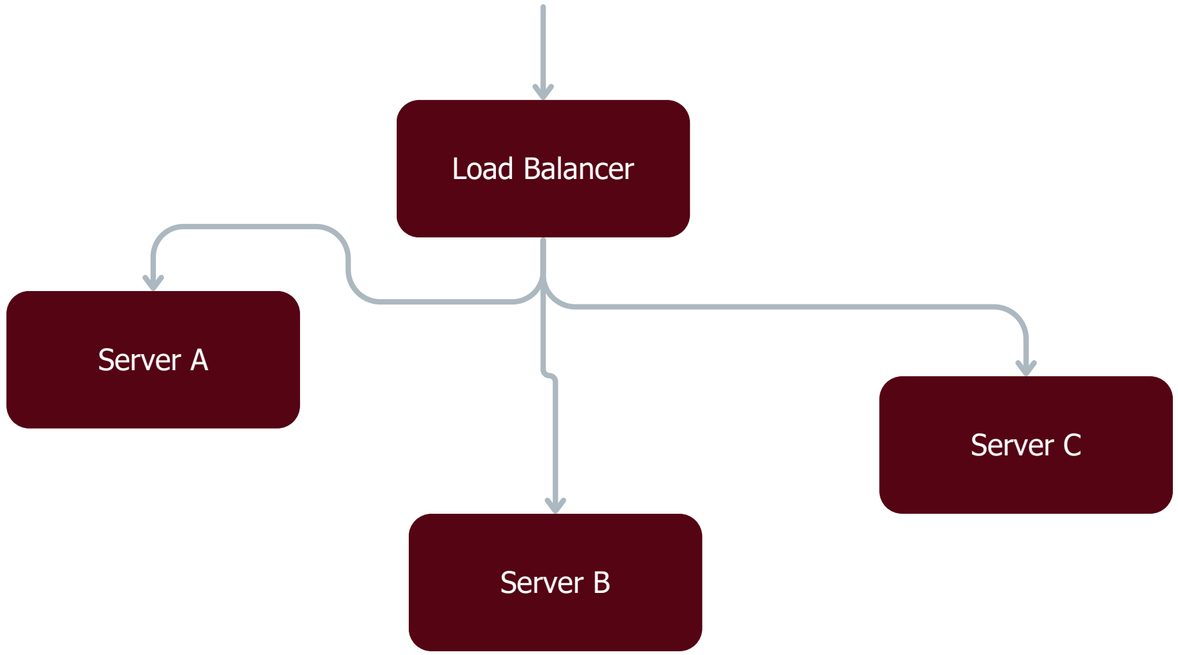
Erläutern Sie die grundsätzliche Funktion eines Load Balancers und wie dieser die Verfügbarkeit von Diensten erhöhen kann.

CLOUDHELDEN.ORG

Lösung

Ein Load Balancer ist ein Gerät oder eine Software, die den Datenverkehr in einem Netzwerk effizient verteilt. Es wird hauptsächlich in Serverumgebungen eingesetzt, um Anfragen von Clients (z.B. Webbrowser, Anwendungs Clients usw.) über mehrere Server zu verteilen.

Durch diesen Mechanismus kann ein Client einen zentralen Endpunkt (IP-Adresse des Load Balancers) ansprechen, der dann den Request im Hintergrund transparent an einen der konfigurierten Server im Load Balancing Pool weitergeleitet.



CLOUDHELDEN.ORG

2.2 High-Level Netzwerkdiagramm

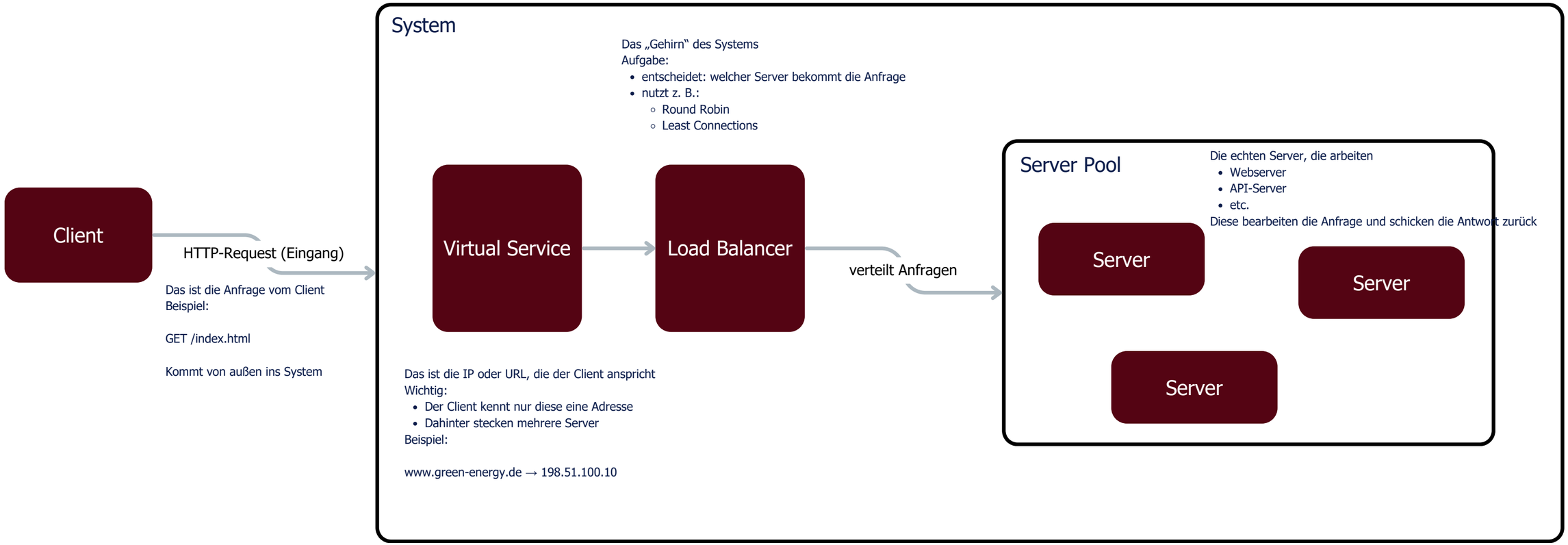
Zur Implementierung des Load Balancers ist eine grundlegende Netzwerkplanung der DMZ notwendig.

Ordnen Sie die untenstehenden Begriffe den richtigen Positionen im High-Level Netzwerkdiagramm zu:

Service-Art	**Zuordnung**
a) Server-Pool	[Gruppe der Backend-Server]
b) Load Balancer	[Vermittlungsinstanz]
c) Virtual-Service	[Endpunkt für Client-Anfragen]
d) HTTP-Request	[Eingehende Anfrage vom Client]

CLOUDHELDEN.ORG

Lösung



CLOUDHELDEN.ORG

2.3 Konfiguration des Load Balancers

Bei der Konfiguration des Load Balancers stellen Sie innerhalb der Administrationsoberfläche auf nachfolgende Einstellungen in Bezug auf den Virtual-Service:

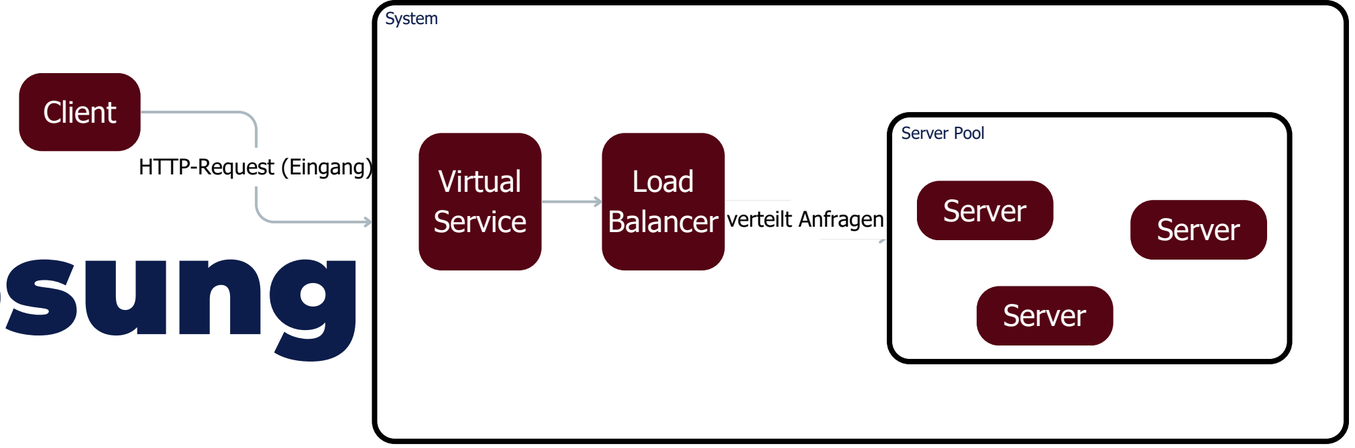
Layer 4: Standard-Optionen (TCP/UDP), Source-IP Persistence, Connection Rate Limiting

Layer 7: HTTP-Profil, SSL-Offloading, Cookie Persistence, URL-basiertes Routing, WAF-Integration

a) Erläutern Sie den Unterschied zwischen einem L4 Load Balancer im Vergleich zu einem L7 Load Balancer und begründen Sie, welche Art innerhalb des Kontextes des Kundenportals aus Ihrer Sicht verwendet werden sollte.

CLOUDHELDEN.ORG

Lösung



Layer 4 (Transport-Schicht)

- Arbeitet mit IP & Port (TCP/UDP)
- Kein Einblick in Inhalte, nur Header (Portnummer, IP-Adressen)
- Schnell & effizient

Beispiel: Weiterleitung basierend auf Port 80/443

Layer 7 (Anwendungsschicht)

- Analysiert Inhalte (HTTP, Cookies, URLs), Einblick in transportierte Payload
- Intelligente Entscheidungen möglich
- Mehr Funktionen, aber komplexer

Beispiele:

- URL-basiertes Routing
- Cookie Persistence
- SSL-Offloading

Für den Einsatz im Kontext des Kundenportals sollte ein L7 Load Balancer verwendet werden, da dadurch mehr Flexibilität bei der Entscheidung von **Lastverteilung** Vorgängen besteht (z.B. URL-basiertes Routing, Cookie-Persistence für Benutzersitzungen).

CLOUDHELDEN.ORG

2.4 Load Balancer und WAF

Im Rahmen der weiteren Diskussion wird auch der Einfluss des Load Balancers auf die IT-Sicherheit betrachtet. Ein Kollege bringt hierbei den Begriff "WAF" auf.

Beschreiben Sie diesen Begriff und nennen Sie 2 Angriffsmuster, vor denen der Einsatz einer WAF schützen kann.

CLOUDHELDEN.ORG

Lösung

WAF steht für "Web Application Firewall" und ist eine Sicherheitslösung, die speziell auf webbasierte Anwendungen ausgerichtet ist.

Hierbei untersucht eine WAF die Kommunikation auf **Anwendungsebene** und kann daher vor Angriffen schützen, die durch den transportierten Payload ausgeführt werden.

Beispiele für Angriffsmuster:

- Cross-Site-Scripting (XSS)
- SQL- oder Script-Injection Attacken

CLOUDHELDEN.ORG

Aufgabe 3: Einführung von IPv6

3.1 Art der Adresse

Die Netzwerkingenieure der GreenEnergy AG starten die Adressierung mittels IPv6 an. Sie aktivieren aus diesem Grund auf den Netzwerkkomponenten zusätzlich das IPv6-Protokoll.
Sie kontrollieren nach der grundsätzlichen Aktivierung des IPv6-Protokolls an der Firewall die Interface-Konfigurationen und stellen dort unter anderem folgende Adresse fest:

fe80::1c4f:9a63:21be

Nennen Sie die Art dieser Adresse und geben Sie den Kommunikationsreichweite an.

CLOUDHELDEN.ORG

Wichtig für Netzwerkfunktionen
Wird intern genutzt für:
Neighbor Discovery (IPv6 „ARP“)
Router-Kommunikation
Routing-Protokolle

Lösung

fe80::1c4f:9a63:21be

Eine IPv6-Adresse besteht aus:
8 Blöcken à 16 Bit (Hex-Zahlen)
Normalform (voll ausgeschrieben):
fe80:0000:0000:0000:0000:1c4f:9a63:21be

IPv6 erlaubt zwei Abkürzungen:

1. **Führende Nullen weglassen**

0000 → 0

2. **Mehrere 0-Blöcke zusammenfassen**

0000:0000:0000:0000 → ::

Art der Adresse → Link Local-Adresse

- Erkennbar am Präfix: fe80::/10
- Wird automatisch auf jedem IPv6-Interface erstellt

Router leitet Adresse nicht weiter nach außen

1. Automatisch erzeugt
Wird automatisch erstellt, sobald IPv6 aktiviert ist
Kein DHCP oder manuelle Konfiguration nötig

2. Nur lokal gültig

- Gilt nur im selben Netzwerk (Layer 2)
- Kommunikation nur mit direkten Nachbarn

3. Nicht routbar

- Geht nicht über Router hinweg
- Verlässt nie das lokale Netzwerk

4. Präfix immer gleich

fe80::/10
Daran erkennt man sofort:
Link-Local-Adresse

3.2 Neighbor Discovery Protocol

Erläutern Sie die Aufgabe des "Neighbor Discovery Protocols" und nennen Sie eine Funktion des Protokolls.

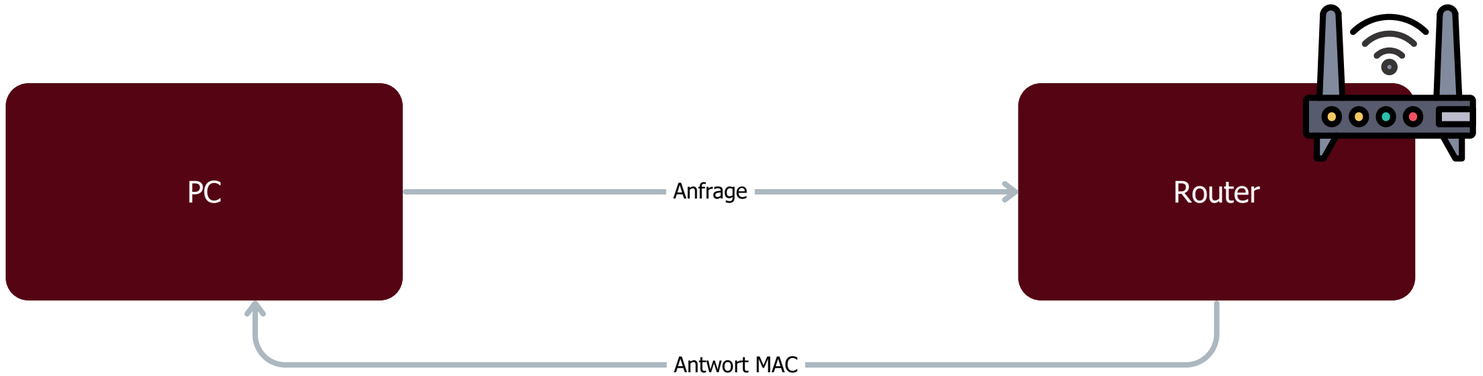
CLOUDHELDEN.ORG

Das Neighbor Discovery Protocol (NDP) ist ein Bestandteil von IPv6 und dient der Ermittlung von Nachbarn im lokalen Netzwerk. Es ersetzt das ARP-Protokoll aus IPv4.

Lösung

Neighbor Discovery Protocol (NDP)
Aufgabe
- Bestandteil von IPv6
- Ersetzt ARP aus IPv4
- Dient zur Ermittlung von Nachbarn im Netzwerk

Kurz:
→ „Wer ist im Netzwerk und wie erreiche ich ihn?"



- PC fragt: „Wer hat diese IPv6?"
- Gerät antwortet mit MAC
- Router meldet sich automatisch

Wichtige Funktionen:

Adressauflösung
→ IPv6-Adresse → MAC-Adresse (wie ARP)

Router Discovery (SLAAC)
→ Geräte finden Router automatisch
→ erhalten Netzinfos (Router Advertisements)

Duplicate Address Detection (DAD)
→ Prüft, ob eine IPv6-Adresse schon vergeben ist

Zu den Funktionen gehören die **Auflösung von IPv6-Adressen in MAC-Adressen** sowie die **automatische Erkennung von Routern** durch Router Advertisements. Außerdem ermöglicht NDP Mechanismen wie **Duplicate Address Detection** zur Vermeidung von Adresskonflikten.

3.3 IPv6-Adressen

Zum besseren Verständnis des Aufbaus und der Schreibweise von IPv6-Adressen informieren Sie sich im Internet zum genauen Adressaufbau und finden dazu folgenden Text:

"Leading zeros MUST be suppressed. For example, 2001:0db8:0001 is not acceptable and must be represented as 2001:db8:1. A single 16-bit 0000 field MUST be represented as 0.
The use of the symbol ':' MUST be used to its maximum capability. For example, 2001:db8:0:0:0:0:2:1
must be shortened to 2001:db8::2:1.
The symbol ':' MUST NOT be used to shorten just one 16-bit 0 field."

Beantworten Sie auf Basis der obenstehenden Informationen nachfolgende Frage:
a) Welche 3 Regeln gelten für die verkürzte Darstellung von IPv6-Adressen? (3 Punkte)
b) Begründen Sie, warum die IPv6-Adresse
2001:db8:1:1:1:1:1:1
nicht weiter verkürzt werden kann.

CLOUDHELDEN.ORG

Lösung

Regel 1: Führende Nullen müssen entfernt werden.

2001:0db8:0001 → 2001:db8:1

Regel 2: Aufeinanderfolgende Gruppen von Nullen werden mit "::" maximal ausgenutzt.

2001:db8:0:0:0:0:2:1 → 2001:db8::2:1

Regel 3: Das Symbol "::" darf nicht verwendet werden, um nur ein einzelnes 16-Bit-Hex-Tet bestehend aus 0 zu kürzen.

2001:db8:0:1 → !! nicht 2001:db8::1

:: nur verwenden, wenn mindestens zwei 0-Blöcke vorhanden sind

b) Warum nicht weiter kürzen?
2001:db8:1:1:1:1:1:1

Die Adresse kann nicht weiter verkürzt werden, da sie keine aufeinanderfolgenden 0-Blöcke enthält. Eine Verkürzung mit „::“ ist nur möglich, wenn mehrere 16-Bit-Blöcke mit dem Wert 0000 vorhanden sind. Da dies hier nicht der Fall ist, ist die Adresse bereits in ihrer kürzesten zulässigen Form dargestellt.

CLOUDHELDEN.ORG

Aufgabe 4: Konzeptionierung einer VPN-Lösung

CLOUDHELDEN.ORG

4.1 VPN und HTTPS

Um seine Attraktivität als Arbeitgeber zu steigern, möchte die Green Energy AG verstärkt Home-Office und mobiles Arbeiten anbieten.
In diesem Zusammenhang fallen die Begriffe VPN und HTTPS.

Erläutern Sie den Unterschied zwischen einer VPN- und einer HTTPS-Verbindung.

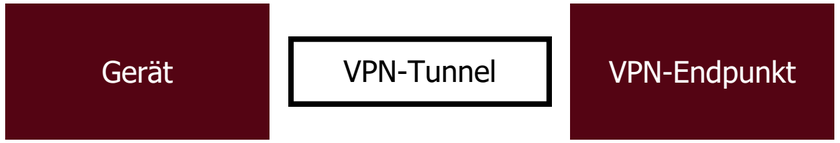
CLOUDHELDEN.ORG

Lösung

VPN (Virtual Private Network) und HTTPS (Hypertext Transfer Protocol Secure) sind beides Technologien, die Sicherheit und Datenschutz im Internet bieten, aber unterschiedliche Anwendungsfälle abdecken.

VPN

Ein VPN erstellt einen sicheren, verschlüsselten Tunnel zwischen einem Gerät und einem VPN-Endpunkt. Alle Daten, die durch diesen Tunnel fließen, sind vor externem Zugriff geschützt.



HTTPS

HTTPS ist eine Erweiterung des HTTP-Protokolls, die eine sichere Kommunikation über das Internet gewährleistet. Es wird hauptsächlich von Webbrowsern und Webservern verwendet, um eine sichere Verbindung zu Websites herzustellen.

CLOUDHELDEN.ORG

4.2 PSK

Die Absicherung der Verbindung erfolgt über einen PSK.
Erläutern Sie den Begriff und die Funktionsweise eines PSK in Bezug auf eine VPN-Verbindung.

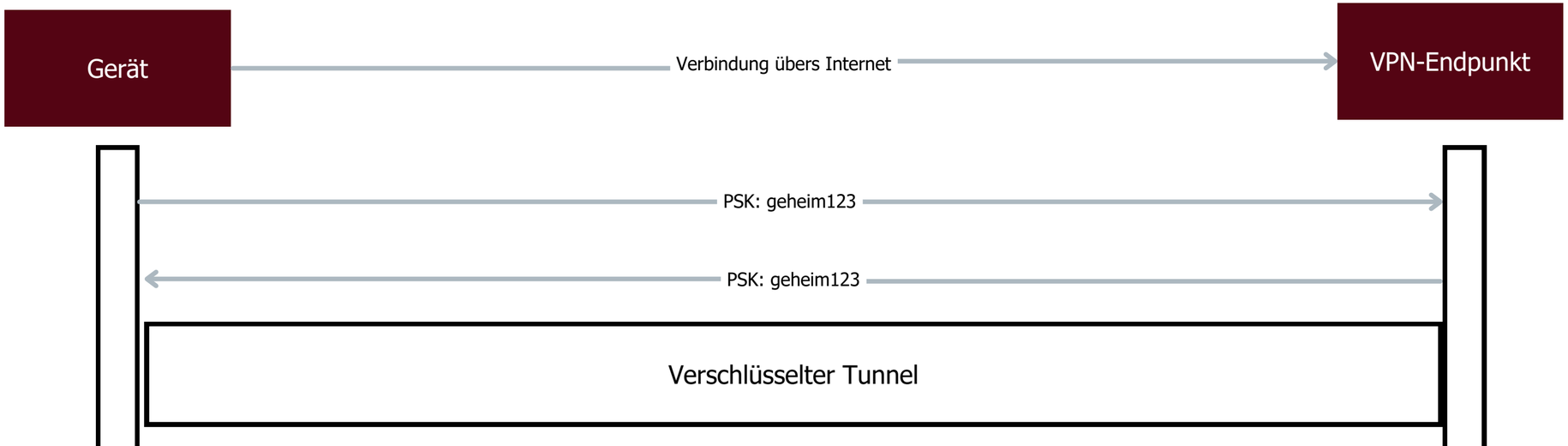
CLOUDHELDEN.ORG

Lösung

PSK steht für "Pre-Shared Key" und bezeichnet eine Methode der Authentifizierung, die auf der gemeinsamen Kenntnis eines Geheimnisses basiert.

In Bezug auf VPN wäre hierfür beispielsweise ein Passwort denkbar, das nur den beiden beteiligten VPN-Partnern bekannt ist und beim Verbindungsaufbau abgeglichen wird.

Ein Pre-Shared Key (PSK) ist ein vorab gemeinsam vereinbartes Geheimnis (z. B. Passwort), das beide VPN-Partner kennen.



CLOUDHELDEN.ORG

4.3 Zertifikate und Schutzziele

Zur Verbesserung der Sicherheit erfolgt die Umstellung des PSK auf ein Zertifikat. Diese stellen die Schutzziele Vertraulichkeit, Authentizität und weitere sicher.

a) Nennen Sie für die Anforderungen "Authentizität" und "Vertraulichkeit" die jeweils passenden Zertifikat Bestandteile. (2 Punkte)

b) Nennen Sie 2 Vorteile, die durch den Einsatz von Zertifikaten gegenüber einem Pre-Shared Key entstehen. (2 Punkte)

Lösung

Zu a)
Anforderungen:
- Authentizität → Digitale Signatur
- Vertraulichkeit → Öffentlicher Schlüssel

Zu b)
Vorteile durch den Einsatz eines Zertifikats gegenüber einem Pre-Shared Key:
- Höhere Sicherheit durch größere Komplexität der verwendeten Schlüssel
- Zentrale Verwaltung der Zertifikate
- Verfügbarkeit bei Kompromittierung über Sperrlisten (CRL)
- Automatische Erneuerung möglich

4.4 IPsec basiertes VPN

Bei der von der Green Energy AG verwendeten Implementierung handelt es sich um ein IPsec-basiertes VPN. Erläutern Sie den Unterschied der beiden Übertragungsmodi "Transportmodus" und "Tunnelmodus".

CLOUDHELDEN.ORG

Lösung

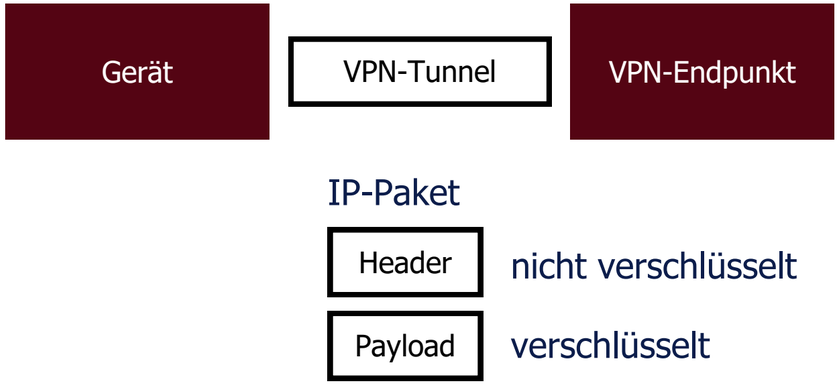
Transportmodus

Im Transportmodus verschlüsselt IPsec nur den Payload des IP-Pakets, nicht den IP-Header. Der ursprüngliche IP-Header bleibt unverändert.

- Direkt zwischen zwei Geräten (Host ↔ Host)

Vorteil: weniger Overhead, schneller

Nachteil: weniger anonym / weniger Schutz



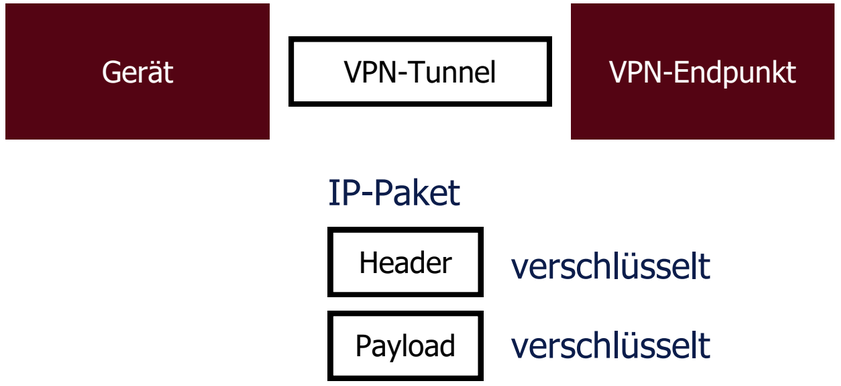
Tunnelmodus

Im Tunnelmodus verschlüsselt IPsec das gesamte IP-Paket und fügt dann einen neuen IP-Header hinzu. Das bedeutet, dass sowohl der ursprüngliche IP-Header als auch der Inhalt des Pakets (der Payload) verschlüsselt sind.

- Typisch für VPN (Gateway ↔ Gateway)

Vorteil: vollständiger Schutz

Nachteil: mehr Overhead



4.5 Untrusted VPN Server Certificate

Beim Versuch des Verbindungsaufbaus erhalten vereinzelte Benutzer folgende Meldung am VPN-Client:

"Security Warning: Untrusted VPN Server Certificate"

a) Nennen Sie eine mögliche Ursache und erläutern Sie einen dazu passenden Lösungsvorschlag für diesen Fehler. (3 Punkte)
b) Zur Reduktion der Komplexität bringen Sie für eine spaetere Weiterentwicklung der VPN-Lösung das Wire Guard-Protokoll in die Betrachtung ein. Nennen Sie jeweils einen Vor- und einen Nachteil im Vergleich zu einem IPsec-basierten VPN. (1 Punkt)

CLOUDHELDEN.ORG

Lösung

Zu a)
Mögliche Fehlerursachen:

- Aussteller des Zertifikats, bzw. die Certificate Authority (CA), ist dem Client nicht bekannt und damit nicht **vertrauenswürdig**
- Verwendeter Common Name (CN) innerhalb des Zertifikats **passt nicht** mit dem vollständig qualifizierten Domänennamen (FQDN), den der Client angesprochen hat
- Abgelaufenes Zertifikat

Ansätze zur Fehlerbehebung:

- Der lokale Zertifikatsspeicher am Client könnte geprueft werden, um herauszufinden, ob die ausstellende Zertifizierungsstelle dem Client bekannt ist, da die ausstellende CA als vertrauenswürdige Root- und/oder Intermediate-CA importiert werden muss
- Das Zertifikat sollte auf korrekte Attribute (CN, DNS-Name, Verwendungszweck, ...) hin überprüft werden. Sind Attribute fehlerhaft, so sollte das Zertifikat neu erzeugt und am VPN-Endpunkt importiertwerden.
- Es sollte überprüft werden, ob das Zertifikat auf der Sperrliste steht. Ist dies der Fall, ist die Ursache zu ermitteln und das Zertifikat neu zu erzeugen und am VPN-Endpunkt zu importieren.

Zu b)

Vorteile von Wire Guard gegenüber IPsec:

- **V**erwendung von modernen Kryptografie-Standards
- Einfachheit in der Konfiguration

Nachteile von Wire Guard gegenüber IPsec:

- Geringere Kompatibilität und Unterstützung innerhalb von Enterprise-Network-Hardware sowie Betriebssystemen
- Noch keine Etablierung als Standard in großen Netzwerk- bzw. VPN-Umgebungen

CLOUDHELDEN.ORG

4.6 Split-Tunneling

Ein Mitarbeiter der Green Energy AG beschwert sich, dass während der VPN-Verbindung die Internet Geschwindigkeit erheblich langsamer ist als ohne VPN.

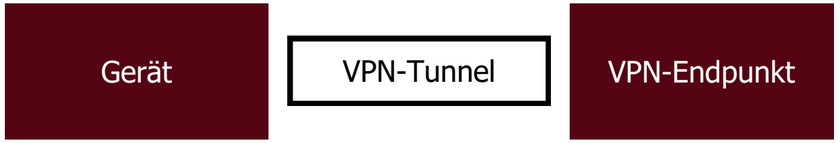
a) Erläutern Sie, warum dieses Problem auftritt. (1 Punkt)
b) Beschreiben Sie den Ansatz "Split-Tunneling" als mögliche Lösung. (1 Punkt)
c) Nennen Sie ein Sicherheitsrisiko, das mit Split-Tunneling verbunden ist. (1 Punkt)

CLOUDHELDEN.ORG

Lösung

Zu a)
Ohne Split-Tunneling wird der gesamte Datenverkehr des Clients über den VPN-Tunnel geleitet (Full-Tunnel-Modus). Das bedeutet, dass auch normaler Internetverkehr (z.B. Streaming, Downloads) über den VPN-Server der Green Energy AG läuft, was die verfügbare Bandbreite erheblich reduziert.

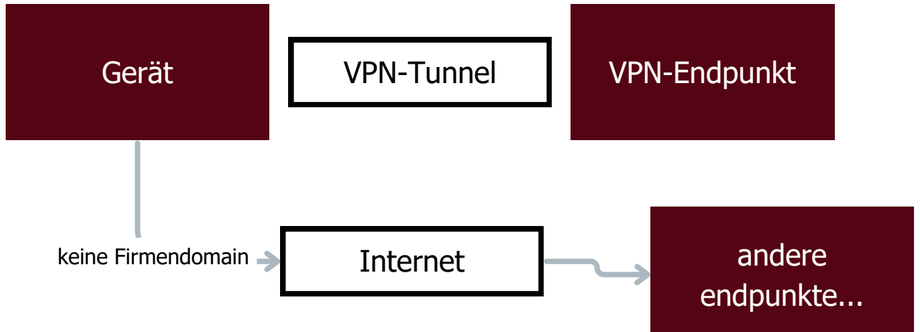
Full-Tunnel:
Gesamter Verkehr über VPN (sicherer, aber langsamer)



Zu b)
Beim Split-Tunneling wird nur der für das Firmennetzwerk bestimmte Datenverkehr durch den VPN-Tunnel geleitet. Normaler Internetverkehr wird direkt über die lokale Internetverbindung des Mitarbeiters geroutet, ohne den Umweg über das VPN.

Split-Tunnel:
Nur Firmen-Traffic über VPN (schneller, aber weniger sicher). In der Praxis wird oft ein Kompromiss gefunden, z.B. bestimmte Domaenen/IPs über VPN, der Rest direkt. Manche Unternehmen verbieten Split-Tunneling aus Compliance-Gründen.

Zu c)
Sicherheitsrisiko: Da der Client gleichzeitig direkt mit dem Internet und mit dem Firmennetzwerk verbunden ist, könnte ein Angreifer den Client als Eintrittspunkt nutzen (z.B. über Malware), um Zugang zum Firmennetzwerk zu erlangen. Der nicht durch VPN geschützte Internetverkehr ist außerdem anfaelliger fuer Man-in-the-Middle-Angriffe.



CLOUDHELDEN.ORG

Kahooooot!